

INTERNATIONAL
STANDARD

国际标准

ISO/IEC
27005

第三版
Third edition
2018-07

译自 <http://www.doc88.com/p-7367816764405.html>

Information technology — Security
techniques — Information security
risk management

信息技术-安全技术-信息安全风险管理
*Techniques de l'information — Techniques de sécurité — Gestion
des risques liés à la sécurité de l'information*



引用代码
Reference number
ISO/IEC 27005:2018(E)

© ISO/IEC 2018

目录

前言

引言

1 范围

2 规范性引用文件

3 术语与定义

4 本文件结构

5 背景

6 信息安全风险管理过程概述

7 环境创建

7.1 总则

7.2 基本准则

7.2.1 风险管理方法

7.2.2 风险评估准则

7.2.3 影响准则

7.2.4 风险接受准则

7.3 范围和边界

7.4 信息安全风险管理组织

8 信息安全风险评估

8.1 信息安全风险评估概述

8.2 风险识别

8.2.1 风险识别导论

8.2.2 资产的识别

8.2.3 威胁识别

8.2.4 现有控件的识别

8.2.5 脆弱点识别

8.2.6 后果的认定

8.3 风险分析

8.3.1 风险分析方法

8.3.2 后果评估

8.3.3 事件可能性评估

8.3.4 风险水平的确定

8.4 风险评估

9 信息安全风险处理

9.1 风险处理概述

9.2 风险修正

9.3 风险保留

9.4 风险规避

9.5 风险转移

10 信息安全风险接受

11 信息安全风险沟通与协商

12 信息安全风险监测与评估

12.1 风险因素的监测与评审

12.2 风险管理的监控、审核和改进

附录 A (资料性) 信息安全风险管理过程范围和边界的确定

附件 B (资料性) 资产的识别与评估及影响评估

附件 C (资料性) 典型威胁实例

附录 D (资料性) 脆弱性和脆弱性评估方法

附录 E (资料性) 信息安全风险评估方法

附录 F (资料性) 风险修正的约束条件

参考文献

前言

ISO（国际标准化组织）和 IEC（国际电工委员会）构成了全球标准化的专门系统。作为 ISO 或 IEC 成员的国家机构通过各自组织为处理特定技术活动领域而设立的技术委员会参与制定国际标准。ISO 和 IEC 技术委员会在共同关心的领域进行合作。与 ISO 和 IEC 联络的其他国际组织、政府和非政府组织也参与了这项工作。在信息技术领域，ISO 和 IEC 建立了一个联合技术委员会 ISO/IEC JTC 1。

ISO/IEC 指令第 1 部分描述了用于开发本文件以及用于进一步维护该文件的过程。特别应注意的是，不同类型的文件需要不同的批准标准。本文件是按照 ISO/IEC 指令第 2 部分的编辑规则起草的（见 www.iso.org/directives）。

注意到该文件的某些元素可能是专利权的主体，ISO 和 IEC 不应负责识别任何或所有此类专利权利。在文件开发过程中确定的任何专利权的细节将在所收到的专利声明的介绍和/或 ISO 清单中（见 www.iso.org/patents）。

在本文件中使用的任何商品名称都是为了方便用户而提供的信息，并不构成背书。

关于标准的自愿性质的解释，有关合格评定的 ISO 特定术语和表达的含义，以及关于 ISO 在技术性贸易壁垒(TBT)中遵守世界贸易组织(WTO)原则的信息。见如下网址：www.iso.org/iso/foreword.html。

本文件由 ISO/IEC JTC 1 技术委员会 SC 27 信息技术 IT 安全技术分委员会编写。

本文件中的任何反馈或问题应指向用户的国家标准机构。这些机构的完整列表可在如下网址查找：www.iso.org/members.html。

这第三版在技术上已被修订，取消和替换了第二版（ISO/IEC 27005:2011），与上一版本的主要变化如下：

- 所有的 ISO/IEC 27001:2005 的直接引用已被删除；
- 已添加明确信息，本文件不包含关于执行 ISO/IEC 27001 中规定的 ISMS 要求的直接指导（见引言）；
- ISO/IEC 27001:2005 已从第 2 章中删除；
- ISO/IEC 27001 已被添加到参考文献目录中；
- 附件 G 及其所有引用已被删除；
- 据此进行了相应的编辑性修改。

引言

本文件提供了组织中信息安全风险管理的指导方针。然而，本文没有提供任何具体的信息安全风险管理方法。由组织来确定他们的风险管理方法，这取决于例如信息安全管理体系（ISMS）的范围、风险管理的环境或行业领域。在本文描述的框架下，可以使用许多现有的方法来实现 ISMS 的要求。本文基于 ISO/IEC 27001 不再要求的识别资产、威胁和脆弱性风险的方法，还有一些可以使用的其他方法。本文件不包含关于实施 ISO/IEC 27001 中给出的 ISMS 要求的直接指导。

本文件与组织内负责信息安全风险管理的管理人员和工作人员有关，并酌情涉及支持此类活动的外部各方。

信息技术 安全技术 信息安全风险管理

1 范围

本文件为信息安全风险管理提供了指导方针。本文件支持 ISO/IEC 27001 中规定的一般概念，旨在帮助基于风险管理方法的信息安全的满意实现。ISO/IEC 27001 和 ISO/IEC 27002 中描述的过程和术语对于完全理解本文件非常重要。

本文件适用于所有类型的试图管理可能危及组织信息安全的风险的组织（例如，商业企业、政府机构、非营利组织）。

2 规范性引用文件

以下文件在正文中被提及，其部分或全部内容构成本文件的要求。对于注有日期的引用文件，只有引用的版本适用。未注明日期的引用文件，引用文件的最新版本（包括任何修订）适用。

ISO/IEC 27000 信息技术 安全技术 信息安全管理体系 概述和词汇

3 术语和定义

就本文件而言，ISO/IEC 27000 和以下给出的术语和定义适用。

ISO 和 IEC 维护用于标准化的术语数据库，地址如下：

- ISO 在线浏览平台：<http://www.iso.org/obp>
- IEC 电子化平台：<http://www.electropedia.org>

4 本文结构

本文件包含信息安全风险管理过程及其活动的描述。背景信息在第 5 章中给出。

信息安全风险管理过程的综述在第 6 章中给出。

所有信息安全风险管理活动如第 6 章所示随后在以下条款中描述：

- 第 7 章：环境创建；
- 第 8 章：风险评估
- 第 9 章：风险处理
- 第 10 章：险接受；
- 第 11 章：风险沟通；
- 第 12 章：风险监测和评估

附件中提供了信息安全风险管理活动的其他信息。环境创建由附件 A（信息安全风险管理过程的范围和边界的确定）支持。资产和影响评估的识别和评估在附件 B 中讨论。附录 C 给出典型威胁的例子和附件 D 讨论脆弱性和脆弱性评估方法。附录 E 列出了信息安全风险评估方法的例子。

风险修正的约束在附件 F 中给出。

第 7 条至第 12 条所列的所有风险管理活动如下：

输入：识别执行活动所需的任何信息。

动作：描述活动。

实施指南：为执行行动提供指导。有些指导可能不适用于所有情况，因此执行其他行动的方式可能更

合适。

输出：标识执行该活动后得到的任何信息。

5 背景

为了识别组织对信息安全要求和建立有效的信息安全管理体系（ISMS）的需求，必须采用系统的方法进行信息安全风险管理。这种方法应该适合组织的环境，尤其应该与整个企业风险管理保持一致。安全工作应及时有效地解决风险。信息安全风险管理应当是所有信息安全管理活动的一个组成部分，并且应当应用于 ISMS 的实施和正在进行的操作。

信息安全风险管理应该是一个持续的过程。该过程应该建立外部和内部环境，评估风险，并使用风险处理计划来处理风险，以执行建议和决策。风险管理在决定应该做什么以及何时将风险降低到可接受的水平之前，分析可能发生的事情和可能的后果。

信息安全风险管理应有助于以下：

- 识别风险；
- 评估风险的后果和发生的可能性；
- 沟通和理解这些风险的可能性和后果；
- 确定风险处理的优先顺序；
- 降低风险的措施优先次序；
- 利益相关者参与风险管理决策并随时了解风险管理状况；
- 监测风险处理的有效性；
- 风险和风险管理过程的定期监测和评审；
- 获取信息以改进风险管理方法；
- 管理人员和员工受到关于风险和采取行动降低风险的教育。

信息安全风险管理过程可应用于整个组织、组织的任何离散部分(例如，部门、物理位置、服务)、任何信息系统、现有的或规划的或受控的特定方面（例如，业务连续性规划）。

6 信息安全风险管理过程概述

在 ISO 31000 中给出了风险管理过程的高层示图，如图 1 所示。

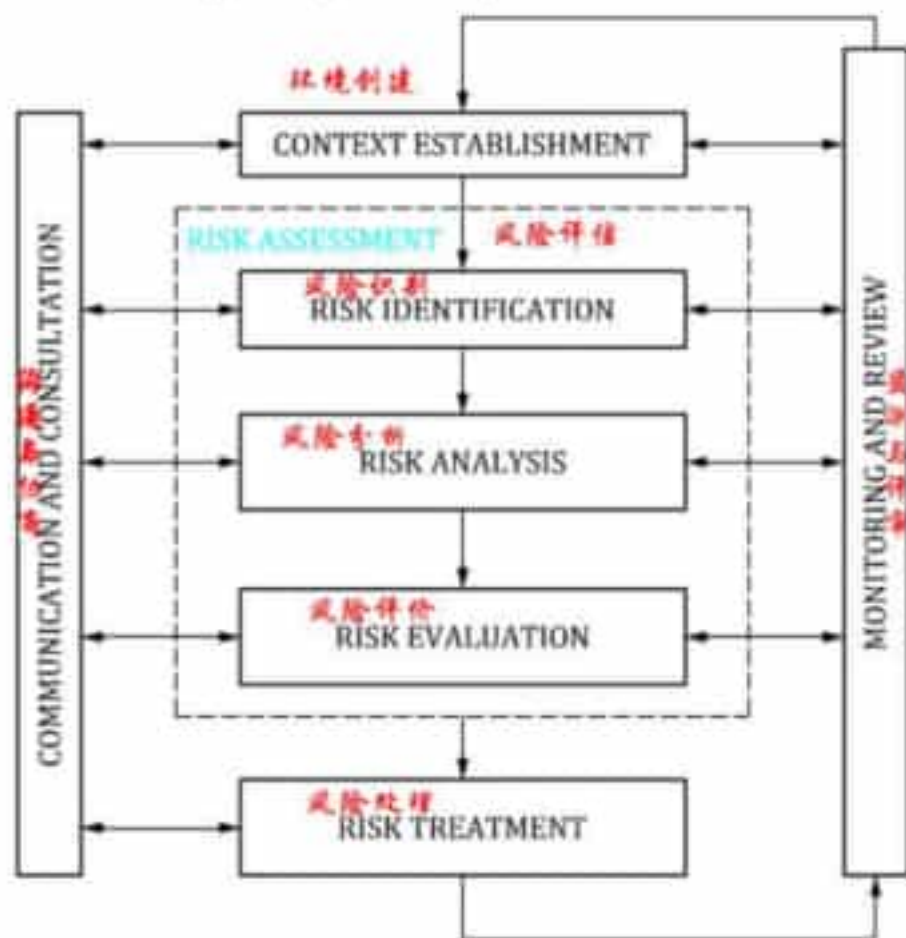


图 1— 风险管理过程

图 2 展示了本文件如何应用风险管理过程。

信息安全风险管理过程包括环境创建（第 7 条）、风险评估（第 8 条）、风险处理（第 9 条）、风险接受（第 10 条）、风险沟通和协商（第 11 条）以及风险监测和审查（第 11 条）。

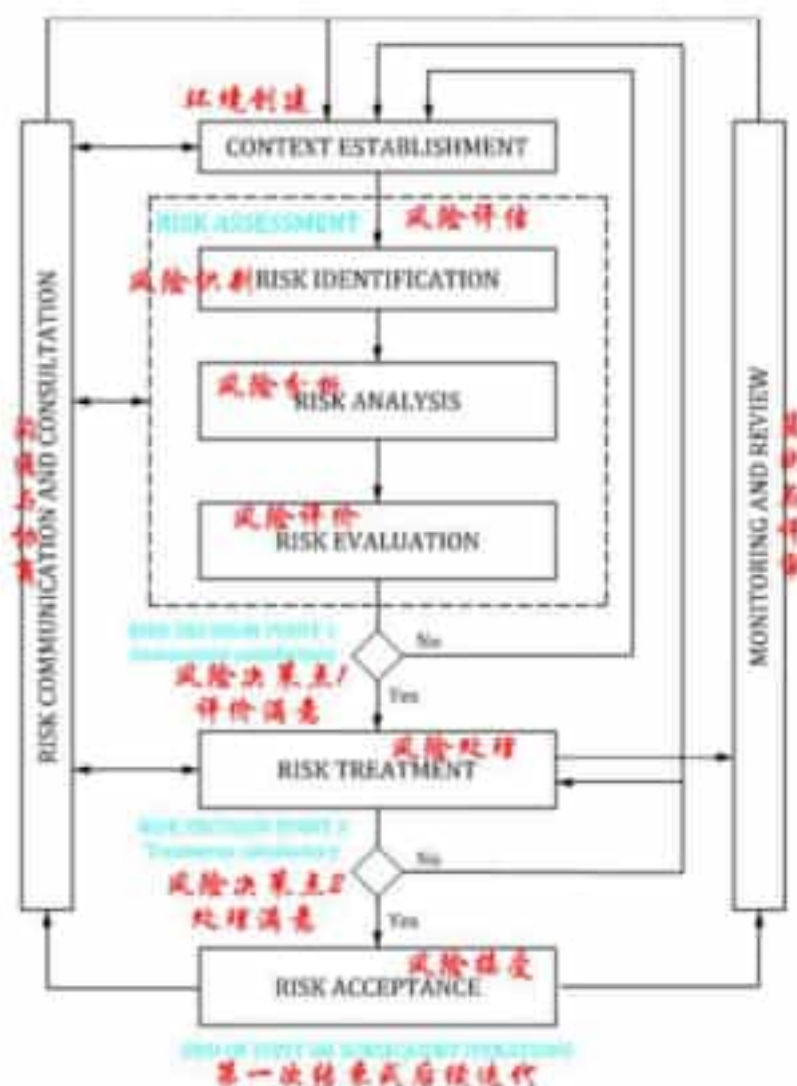


图 2—信息安全风险管理过程的说明

如图 2 所示，举例说明，信息安全风险管理过程可以被迭代用于风险评估和/或风险处理活动。迭代的风险评估方法可以在每次迭代中增加评估的深度和细节。迭代方法在识别控制所费时间最小化与确保适当地评估高风险的努力之间提供了良好的平衡。

首先创建环境。然后，进行风险评估。如果这提供了足够的信息来有效地确定将风险调整到可接受水平所需的行动，那么任务就完成了，随后进行风险处理。

如果信息不足，则可能在整个范围的有限部分上进行环境修订（例如，风险评估准则、风险接受准则或影响准则）后的风险评估的另一次迭代（参见图 2，风险决策点 1）。

风险处理的有效性取决于风险评估的结果。

注意，风险处理包括一个周期性的过程：

- 评估风险处理；
- 决定剩余风险水平是否可接受；
- 如果风险水平不可接受，则产生新的风险处理；和
- 评估处理的有效性。

风险处理不可能立即导致可接受的残留风险水平。

在这种情况下，如果需要的话，可以要求改变环境参数（例如风险评估、风险接受或影响准则）后的

另一次迭代风险评估，随后进行进一步的风险处理（参见图 2，风险决策点 2）。

风险接受活动必须确保组织的管理者明确地接受剩余风险。在控制实施被省略或推迟的情况下，例如由于成本，这是特别重要的。

在整个信息安全风险管理过程中，将风险及其处理传达给适当的管理者和操作人员非常重要。甚至在处理风险之前，关于已识别风险的信息对管理事件是非常有价值的，并且可以帮助减少潜在的损害。管理人员和工作人员了解风险、用以减轻风险的控制措施的性质以及组织关注的领域，有助于以最有效的方式处理事件和意外事件。应当记录信息安全风险管理过程的每个活动以及来自两个风险决策点的详细结果。

ISO/IEC 27001 规定在 ISM 的范围、边界和环境中实施的控制需要基于风险。信息安全风险管理过程的应用可以满足这一要求。有许多方法可以确定控制来实施所选择的风险处理选项。

组织应建立、实施和保持程序，以确定适用于下列各项的法律要求：

- 标准的选择风险评估（7.2.2）、风险影响（7.2.3）和风险接受（7.2.4）的准则；
- 信息安全风险管理的范围和边界的确定（7.3 和 A.2）；
- 风险评估（8.4）；
- 风险处理（9.1）和降低风险计划的实施（9.2 和附件 F）；
- 风险管理的监控、审查和改进（12.2）；
- 资产识别（B.1.3）和资产评估（B.2.3）；和
- 风险估计（见 E.2.1 中的示例）。

7 环境创建

7.1 总则

输入：所有与信息安全风险管理环境的创建有关的组织信息。

行动：应创建信息安全风险管理的外部 and 内部环境，包括建立信息安全风险管理所必需的基本准则（7.2）、确定范围和边界（7.3）以及建立适当的机构来实施安全风险管理（7.4）。

实施指南：

确定信息安全风险管理的目的非常重要，因为这影响整个过程，尤其是环境的创建。这个目的可以是：

- 支持 ISMS；
- 守法和尽职的调查证据；
- 制定业务连续性计划；
- 制定事故应急预案；和
- 描述产品、服务或机制的信息安全要求。

下文 7.2、7.3 和 7.4 进一步讨论了支持 ISMS 所需的环境创建元素的实现指南。

输出：信息安全风险管理过程的基本准则、范围和边界的规范，以及信息安全风险管理过程组织。

7.2 基本准则

7.2.1 风险管理方法

根据风险管理的范围和目标，可以采用不同的方法。该方法对于每次迭代也可以是不同的。

应当选择或开发涉及基本准则的适当的风险管理方法，例如：风险评估准则、影响准则、风险接受准则。

此外，组织应评估是否有必要的资源用于：

- 进行风险评估并建立风险处理计划；
- 确定和实施方针和程序，包括实施所选择的控制；
- 对控制实施监测；以及

——对信息安全风险管理过程实施监测。

7.2.2 风险评估准则

为了评估组织的信息安全风险，应考虑以下因素制定风险评估标准：

- 业务信息处理的战略价值；
- 涉及的信息资产的临界性；
- 运营和业务的重要性、可用性、保密性和完整性；
- 利益相关者的期望和观念，以及对商誉和声誉的负面影响；

此外，风险评估准则可以用来指定风险处理的优先次序。

7.2.3 影响准则

注：ISO 31000 使用“后果准则”的概念而不是“影响准则”。

应根据信息安全事件对组织造成的损害程度或成本来制定和具体规定影响准则。考虑下列因素：

- 受影响的信息资产的分类级别；
- 信息安全的破坏（如机密性、完整性和可用性的丧失）；
- 运作的失误（内部或第三方）；
- 商业和财务价值的损失；
- 计划和最终期限的毁坏；
- 声誉的损毁。

7.2.4 风险接受准则

应制定和具体规定风险接受准则。风险接受准则通常取决于组织的方针、目的、目标和利益相关者的利益。

组织应该为风险接受水平确定自己的尺度。在开发过程中应考虑以下因素：

- 风险接受准则可以包括多个具有预期目标风险水平的阈值，但对高级管理人员规定在规定的情况下接受高于此水平的风险；
- 风险接受准则可以表示为估计利润（或其他商业利益）与估计风险的比率；
- 不同的风险接受准则可适用于不同类别的风险；
- 风险接受准则可以包括对未来额外处理的要求，例如，如果批准和承诺采取行动，在规定的时段内将其降低到可接受的水平，则可以接受风险。

风险接受准则可以根据风险预期存在的时间而不同，例如风险可以与临时或短期活动相关联。建立风险接受准则应考虑以下事项：

- 商业标准；
- 运作；
- 技术；
- 财力；
- 社会和人道主义因素。

更多信息可在附件 A 中找到。

7.3 范围和边界

组织应明确信息安全风险管理的范围和边界。

需要确定信息安全风险管理过程的范围，以确保在风险评估中考虑所有相关资产。此外，需要识别边界以解决通过这些边界可能产生的风险。

应该收集有关组织的信息，以确定其所处的环境及其与信息安全风险管理过程的相关性。

当定义范围和边界时，组织应考虑以下信息：

- 组织的战略业务目标、战略和方针；
- 业务流程；
- 组织的职能和结构；
- 组织的信息安全方针；
- 组织对风险管理的总体方法；
- 信息资产；
- 组织的地点及其地理特征；
- 影响组织的制约因素；
- 利益相关者的期望；
- 社会文化环境；
- 接口（即与环境的信息交流）。

此外，组织应提供任何排除范围的理由。

风险管理范围的示例可以是 IT 应用程序、IT 基础设施、业务流程或组织确定的部分。

进一步的信息可在附件 A 中找到。

7.4 信息安全风险管理组织

确定和保持信息安全风险管理过程的组织和责任。以下是该组织的主要职责和职责：

- 开发适合组织的信息安全风险管理体系；
- 利益相关者的识别和分析；
- 确定组织内部和外部所有各方的角色和职责；
- 在组织和利益相关方之间建立所需的关系，包括与组织高层风险管理职能（例如运作风险管理）的接口，以及与其他相关项目或活动的接口；
- 确定决策升级路径；
- 要保存的记录规范。

该组织应由组织的适当管理者批准。

8 信息安全风险评估

8.1 信息安全风险评估概述

输入：建立信息安全风险管理过程的基本准则、范围和边界。

行动：风险应当被识别、量化或定性地描述，并且根据与组织相关的风险评估准则和目标来划分优先级。

实施指南：

风险是由不必要事件的发生而产生的后果和事件发生的可能性的组合。风险评估量化或定性地描述风险，并使得管理人员能够根据其感知的严重性或其他已建立的准则对风险进行排序。

风险评估包括下列活动：

- 风险识别（8.2）；
- 风险分析（8.3）；
- 风险评估（8.4）。

风险评估确定信息资产的价值，识别存在（或可能存在）的可应用的威胁和脆弱点，识别现有控制及其对所识别风险的影响，确定潜在后果，最后，优先考虑派生的风险，并将它们针对环境创建中的风险评估准则进行排序。

风险评估通常是在两次（或更多）迭代中进行的。首先，进行高层评估，以确定可能需要进一步评估的潜在高风险。下一次迭代可以进一步深入地考虑初始迭代中揭示的潜在高风险。如果这些信息不足以评估风险，那么可以进一步详细分析，可能涉及整个范围的一部分，并且可能使用不同的方法。

组织应根据风险评估的目的和目标选择自己的风险评估方法。

关于信息安全风险评估方法的讨论可以在附录 E 中找到。

输出：根据风险评估准则优先评估的风险清单。

8.2.1 风险识别导论

风险识别的目的是确定可能发生什么导致潜在损失，并深入了解如何发生、何处发生以及为什么可能发生损失。下列条款中描述的步骤将会收集风险分析活动的输入数据。

风险识别应该包括的风险，无论其来源是否在组织的控制之下，即使风险源或原因可能不明显。

注：根据应用的方法，后续条款中描述的活动可以按不同的顺序进行。

8.2.2 资产识别

输入：风险评估的范围和边界、业主名单、地点、功能等。

活动：确定范围内的资产。

实施指南：

资产是对组织有价值的东西，因此需要保护。为了识别资产，应该记住，信息系统不仅包括硬件和软件。

资产识别应该在适当的细节等级上进行，为风险评估提供足够的信息。资产识别中使用的细节等级影响风险评估期间收集的信息总量。在风险评估的进一步迭代中，可以细化该等级。

资产所有者应识别每个资产，以规定对资产的责任和义务。资产所有者可能对资产不具有产权，但酌情对其生产、开发、维护、使用和安全负有责任。资产所有者通常是确定资产对组织的价值的最合适的人（资产评估见 8.3.2）。

评估边界是组织确定由信息安全风险管理过程管理的资产的边界。

有关信息安全的资产识别和估价的更多信息可在附件 B 中找到。

输出：要进行风险管理的资产清单和与资产相关的业务流程及其相关性。

8.2.3 威胁识别

输入：从事件审查、资产所有者、用户和其他来源获得的威胁信息，包括外部威胁目录。

活动：应确定威胁及其来源。

实施指南：

威胁有可能损害信息、过程和系统等资产，因此也会损害组织。威胁可以是自然的或人类的起源，也可以是偶然的或故意的。应确定意外和故意威胁源。

威胁可能来自组织内部或外部。应广泛地和按类型（例如：未经授权的行动、物理损坏、技术故障）来识别威胁；然后，在适当的情况下，识别通用类中的单个威胁。这意味着没有威胁被忽视，包括意想不到的，但所需的工作量是有限的。

一些威胁会影响不止一种资产。在这种情况下，它们会造成不同的影响，取决于哪些资产受到影响。

可以从资产所有者或用户、人力资源人员、设施管理和信息安全专家、物理安全专家、法律部门和其他相关机构，包括法律机构、天气当局、保险公司和政府当局，获得威胁识别和估计发生可能性的输入（见 8.3.3）。在应对威胁时，也应考虑环境和文化方面的问题。

在当前评估中应考虑事故和过去威胁评估的内部经验。查阅其他威胁目录（可能特定于组织或企业）以完成相关通用威胁列表是值得的。威胁目录和统计数据可从行业团体、政府、法律机构、保险公司等获得。

当使用威胁目录或先前的威胁评估结果时，应该知道相关威胁有持续的变化，特别是如果业务环境或信息系统发生变化。

关于威胁类型的更多信息可以在附件 C 中找到。

输出：识别威胁类型和来源的威胁列表。

8.2.4 现有控件的识别

输入：控制文件，风险处理实施计划。

活动：应该确定现有的和计划的控制。

实施指南：

应当对现有的控制进行识别，以避免不必要的工作或成本，例如：重复控制。

此外，在识别现有控制的同时，应进行检查以确保控制正常工作——应限制对已有 ISM 审计报告的参考在这个任务中花费的时间。如果控件不按预期工作，这可能造成脆弱点。应当考虑到所选择的控制（或策略）在运作中失败的情况，因此需要互补的控制来有效地解决所识别的风险。

根据风险处理实施方案计划实施的控制应当以与已经实施的相同的方式加以考虑。

现有的或计划的控制可被认定为无效或不充分或不合理。如果不合理或不充分，则应检查该控制以确定是否应被移除、是否应被另一个更合适的控制所替代，或者该控制是否应保持在适当的位置，例如，出于成本原因。

为了识别现有的或计划的控制，下列活动可能是有益的：

——如果信息安全管理过程很好地记录了所有现有或计划中的控制，并且这些控制的实施状态应当可用，则评价包含有关控制的信息的文件（例如，风险处理实施计划）；

——与负责信息安全的人员（例如，信息安全专员和信息系统安全专员、物业管理者或运营经理）和用户进行核实，以确定哪些控制是真正在受管制的信息过程或信息系统中得到实施；

——对物理控制进行现场评价，将实施的控制与应当存在的控制列表进行比较，并检查实施的控制是否正确和有效地工作；

——审核评价结果。

输出：所有现有和计划的控制列表，它们的实现和使用状态。

8.2.5 脆弱点识别

输入：已知威胁列表、资产和现有控制列表。

活动：应该识别可被威胁利用对资产或组织造成损害的脆弱点。

实施指南：

脆弱点可以在以下领域被识别：

——组织；

——过程和程序；

——管理程序；

——人员；

——物理环境；

——信息系统配置；

——硬件、软件或通信设备；

——对外部各方的依赖。

脆弱点的存在本身不会造成伤害，这需要威胁出现利用它。没有对应威胁的脆弱点可能不需要执行控制，但是应该识别和监视其变化。应当注意，不正确地实施或错误地使用的控制或控件的故障本身可能是脆弱点。根据它所处的环境，控制可以是有效的或无效的。相反，不具有相应脆弱性的威胁可能不会导致

风险。

脆弱点可能与资产的属性相关，这些属性可以以某种方式或用于某种目的，而不是在购买或制造资产时预期的目的。需要考虑从不同来源产生的脆弱性，例如，那些固有的或外在的资产。

脆弱点和脆弱点评估方法的示例可以在附件 D 中找到。

输出：与资产、威胁和控制相关的脆弱点列表；供审查用的与任何已识别的威胁无关的脆弱点列表。

8.2.6 后果的认定

输入：资产列表、业务流程列表以及与资产及其相关性相关的威胁和脆弱点列表。

活动：应该确定机密性、完整性和可用性的损失可能对资产造成的后果。

实施指南：

后果可能是有效性的丧失、不利的经营条件、营业损失、声誉损害等。

这种活动识别了由事故场景引起的对组织的损害或后果。事件场景是在信息安全事件中威胁利用某一脆弱性或一组脆弱性的描述。

确定事件场景的影响要考虑在环境创建活动期间的确定影响准则。它可以影响一个或多个资产或资产的一部分。因此，资产可以具有分配价值，既考虑到其财务成本，也考虑到如果它们受到损坏或损伤的业务后果。后果可以是暂时性的，也可以是永久性的，如资产的破坏。

组织应根据如下诸方面（但不限于）确定事件情景造成的后果：

- 调查和维修时间；
- （工作）时间的损失；
- 机会的丧失；
- 健康和安全；
- 用于修复损坏的特定技能的财务成本；
- 形象信誉和商誉。

对技术脆弱点评估的细节可以在 8.3 中找到。

输出：与资产和业务流程相关的事件场景列表。

8.3 风险分析

8.3.1 风险分析方法

根据资产的临界性、已知脆弱点的程度以及涉及组织的先前事件，可以以不同程度的细节进行风险分析。风险分析方法可以是定性的或定量的，或者是这些的组合，取决于环境。在实践中，往往首先使用定性分析来获得风险水平的一般特征，并揭示主要风险。稍后，可能需要对主要风险进行更具体或定量的分析，因为进行定性分析通常比定量分析不那么复杂和比较便宜。

分析的形式应该与作为环境创建的一部分而确定风险评估准则相一致。

分析方法的进一步细节如下：

a) 定性风险分析：

定性风险分析使用限定属性的尺度来描述潜在后果的大小（例如，低、中和高）以及这些后果发生的可能性。定性分析的一个优点是便于所有相关人员理解，而缺点是依赖于主观选择量表。

这些尺度可以适应或调整以适应环境，不同的描述可以用于不同的风险。定性风险分析可用于：

- 作为初步筛选活动来识别需要更详细分析的风险；
- 这种分析适合于决策；
- 数值数据或资源不足以进行定量风险分析。

定性分析应使用事实信息和可用数据。

b) 定量风险分析：

定量风险分析使用具有数值的尺度（而不是定性风险分析中使用的描述性尺度），利用来自各种来源的数据对结果和可能性进行衡量。分析的质量取决于数值的准确性和完整性和所使用的模型的有效性。在大多数情况下，定量风险分析使用历史事件数据，这提供了与组织的信息安全目标和关注点直接相关的优点。缺点是对新的风险或信息安全脆弱点缺乏这样的数据。定量方法的缺点可能发生在没有实际、可审计的数据的情况下，从而造成风险评估的价值和准确性的错觉。

表达后果和可能性的方式以及以它们的组合来提供风险水平的方式将根据风险的类型和风险评估输出的用途而变化。在分析中应该考虑后果和可能性的不确定性和可变性，并有效地进行沟通。

8.3.2 后果评估

输入：已识别的相关事件场景的列表，包括威胁、脆弱点、受影响资产、对资产的后果和业务流程的识别。

活动：应评估可能的或实际的信息安全事件可能对组织的业务影响，同时考虑信息安全被破坏的后果，例如机密性损失、完整性或可用性损失。

实施指南：在确定所有被审核的资产之后，在评估后果时应当考虑分配给这些资产的价值。

使用业务影响概念来衡量后果。业务影响价值可以以定性和定量的形式表示，因为任何货币赋值的方法通常都可以为决策提供更多的信息，从而促进更有效的决策过程。

资产评估开始于根据资产的临界性对资产依其对实现组织业务目标的重要性为条件进行分类。然后使用两个度量来确定估值：

- 资产的重置价值：回收、清理和替换信息的成本（如果可能的话）；

- 资产丧失或损坏的业务后果，例如由于信息和其他信息资产的披露、修改、不可用和/或销毁而可能产生的不良业务和/或法律或监管后果。

这种估值可以通过业务影响分析来确定。根据资产对组织实现其业务目标的重要性，由业务结果确定的价值通常显著高于简单的重置成本。资产评估是事件场景影响评估中的一个关键因素，因为事件可以影响不止一个资产（例如，从属资产），或者仅影响资产的一部分。不同的威胁和脆弱点对资产有不同的影响，例如机密性、完整性或可用性的损失。因此，后果评估与基于业务影响分析的资产评估有关。

后果或业务影响可以通过对一个事件或一组事件的结果建模，或者通过从实验研究或过去的推断来确定。

结果可以用货币、技术或人力影响准则或与组织有关的其他准则来表示。在某些情况下，需要不止一个数值来详述不同时间、地点、组成情况的后果。

在时间和财务上的后果应该用同样的方法来测量威胁可能性和脆弱点。在定量或定性方法上要保持一致性。

有关资产评估和影响评估的更多信息可在附件 B 中找到。

输出：关于资产和影响准则所表达的事件情景的评估结果的列表。

8.3.3 事件可能性评估

输入：确定的相关事件场景列表，包括对威胁、受影响的资产、被利用的脆弱性以及资产和业务流程的后果的识别。同时，列出所有现有的和计划的控制，它们的有效性、实现和使用状态。

活动：应该评估事件场景的可能性。

实施指南：

在确定事件场景之后，需要使用定性或定量分析技术评估每个场景和影响发生的可能性。这应该考虑到威胁发生的频率以及脆弱性被利用的容易程度，考虑到：

- 威胁可能性的经验和适用性统计数字；

- 对于蓄意的威胁源：随时间而变的动机和能力，潜在攻击者可用的资源，以及潜在攻击者对资产

吸引力和脆弱性的感知；

——意外威胁来源：地理因素，例如接近化学或石油工厂，极端天气情况的可能性，以及影响人为失误和设备故障的因素；

——单个和集聚的脆弱性；

——现有的控制以及它们如何有效地减少脆弱性。

例如，信息系统可能容易受到伪装用户身份和滥用资源的威胁。由于缺乏用户认证，用户身份伪装的脆弱性可能很高。另一方面，尽管缺乏用户身份验证，但因为滥用资源的方式是有限的，滥用资源的可能性可能很低。

根据准确性的需要，可以对资产进行分组，或者有必要将资产拆分为其元素，并将场景与元素关联起来。

例如，在不同的地理位置，对同一类型资产的威胁的性质可能会改变，或者现有控制的有效性可能会有所不同。

输出：事件场景的可能性（定量的或定性的）。

8.3.4 确定风险水平

输入：与资产和业务流程及其可能性（定量的或定性的）相关的事件场景列表。

活动：应该为所有相关的事件场景确定风险级别。

实施指南：

风险分析为风险的可能性和后果赋值。这些值可以是定量的，也可以是定性的。风险分析基于评估的后果和可能性。

此外，它还可以考虑成本效益、涉众的关注和其他变量，以进行风险评估。估计的风险是事件场景的可能性及其后果的组合。

不同的信息安全风险分析方法或方法的示例可以在附件 E 中找到。

输出：带有等级赋值的风险列表。

8.4 风险评估

输入：带有风险等级和风险评估标准的风险列表。

活动：应将风险水平与风险评估标准和风险接受标准进行比较。

实施指南：

与风险评估有关的决策的性质和用于做出这些决策的风险评估标准是在建立环境时确定的。在这个阶段，当更多地了解到所确定的特定风险时，应该更详细地评价这些决策和环境。为了评估风险，组织应该将估计的风险（使用附件 E 中讨论的选定方法或方法）与环境建立过程中确定的风险评估标准进行比较。

用于决策的风险评估标准应与所确定的外部和内部信息安全风险管理环境一致，并考虑组织的目标和利益相关方的观点等。风险评估活动中的决策主要基于可接受的风险水平。然而，结果、可能性和对风险识别和分析的信心程度也应该被考虑。多个低风险或中等风险的集合可能导致更高的总体风险，因此应该相应地加以解决。

考虑应该包括：

——信息安全属性：如果一个准则与组织无关（例如保密性的丧失），那么影响该准则的所有风险可能都不相关；

——由特定资产或一组资产支持的业务流程或活动的重要性：如果确定流程的重要性较低，与之相关的风险应比影响更重要的流程或活动的风险考虑得更少；

风险评估利用风险分析所得对风险的理解，对未来的行动做出决策。决策应包括：

——是否应进行某项活动；

——考虑到估计的风险水平，排列处理风险的顺序。

输出：根据导致这些风险的事件场景的风险评估准则，按优先级排序的风险列表。

9 信息安全风险处理

9.1 风险处理概述

输入：根据导致这些风险的事件场景的风险评估准则，按优先级排序的风险列表。

活动：应选择降低、保留、规避或转移风险的控制，并确定风险处理计划。

实现指导：

风险处置有四种选择：风险降低（见 9.2）、风险保留（见 9.3）、风险规避（见 9.4）和风险转移（见 9.5）。图 3 展示了图 2 所示的信息安全风险处理过程中的风险处理活动。

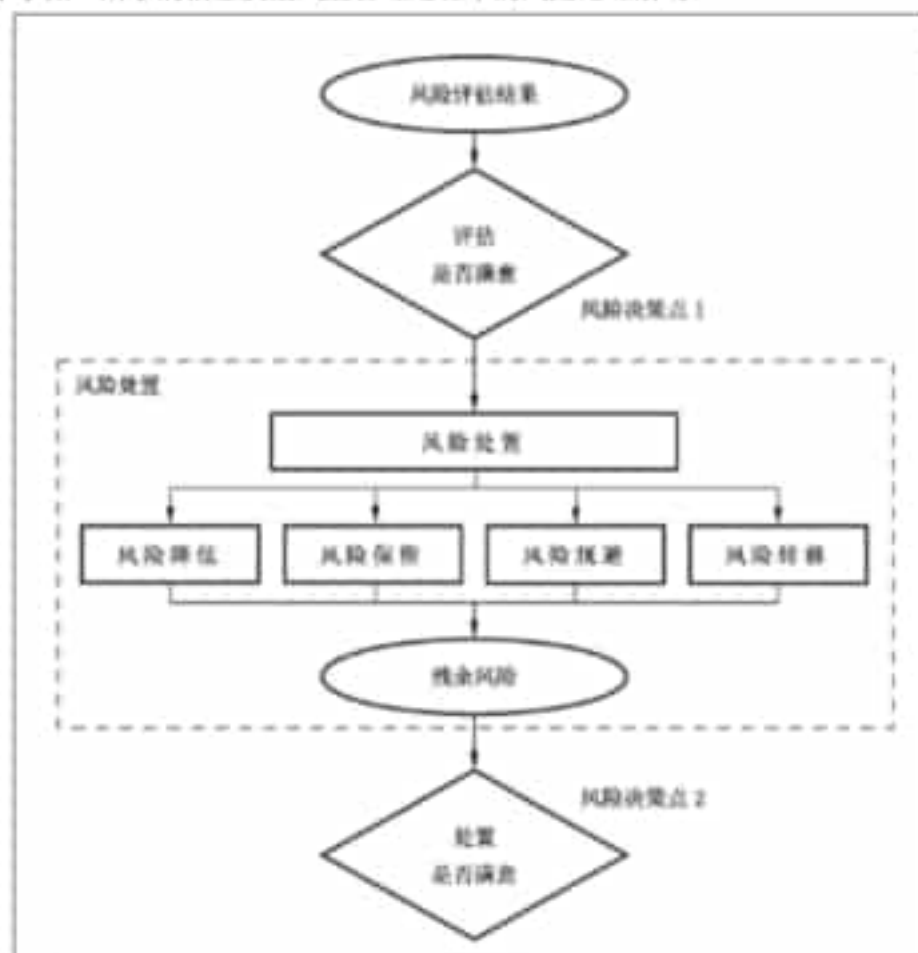


图 3—风险处置活动

选择风险处置选项时，宜基于风险评估结果以及实施这些选项的预期成本和收益。

宜实施那些以相对较低的支出就可大量减少风险的选项。进一步改进的选项可能是不经济的，需要判断其是否是合理的。

通常情况下，如果合理可行，宜尽量降低风险的负面后果，无需考虑任何绝对准则。管理者宜考虑罕见的但严重的风险。在这种情况下，可能需要实施严格经济意义上不合理的控制措施（例如，考虑覆盖特定高风险的业务连续性控制措施）。

风险处置的四个选项不是互相排斥的。有时，组织可以大幅受益于选项的组合，如降低风险的可能性，减轻其后果，并转移或保留任何残余风险。

某些风险处置能有效地解决多个风险（例如，信息安全培训和意识）。宜制定风险处置计划，明确标识出各风险处置的实施优先顺序和时限。优先级可以通过各种技术来确立，包括风险排序、成本效益分析。组织

的管理者有责任决定实施控制措施的成本与预算安排之间的平衡。

就成本比较而言,现有控制措施的识别可能得出这些现有控制措施已超出当前需要的结论,包括维护。如果考虑去除多余的或不必要的控制措施(尤其是如果这些控制措施需要高昂的维护成本),那么宜考虑信息安全和成本因素。由于控制措施会相互影响,去除多余的控制措施可能会降低现有的整体安全。此外,保留而不是去除多余的或不必要的控制措施可能更便宜。

考虑风险处置选项时,宜考虑到:

- 受影响方怎样感知风险
- 与各方沟通的最适当方式。

违规是组织面临的风险,宜实现处置选项以限制这种可能性。在环境建立活动中识别的所有约束(组织的、技术的、结构的等)宜在风险处置期间予以考虑。

一旦确定了风险处置计划,就需要确定残余风险。这需要在考虑到所建议的风险处置的预期效果下,进行风险评估的更新或再次迭代。如果残余风险仍不能满足组织的风险接受准则,则转入风险接受之前,可能有必要进行风险处置的进一步迭代。

输出:组织管理者决定接受的风险处置计划和残余风险。

9.2 风险降低

活动:应通过引入、取消或改变控制来管理风险水平,而使剩余风险可以重新评估为可接受的。

实施指南:

宜选择适当的和合理的控制措施来满足风险评估和风险处置所确定的要求。这种选择还应考虑到实施控制或技术、环境和文化方面的成本和时间框架。

通常可以通过适当选择的信息安全控制措施来降低系统的总拥有成本。通常,控制措施可提供下列保护类型中的一种或多种:纠正、消除、预防、影响最小化、威慑、检测、恢复、监视和意识。在选择控制措施时,重要的是权衡获取、实施、管理、运行、监视和保持控制措施的成本与被保护资产的价值。而且,宜考虑某些控制措施在风险降低和开拓新业务机会的潜力方面带来的投资回报。此外,宜考虑到确定和实施新的控制措施或修改现有控制措施时所需的专业技能。

ISO/IEC 27002 提供了有关控制措施的详细信息。

有许多约束会影响控制措施的选择。技术约束,诸如,性能要求,可管理性(运行支持要求)和兼容性问题,可能会妨碍某些控制措施的使用或导致人为失误,致使或者控制措施无效,产生安全错觉,或者比没有控制措施还甚至增加风险(例如,要求复杂的口令,但没有适当的培训,导致用户将口令写下)。而且,控制措施可能会影响性能。管理者宜设法找出解决方案以保证足够的信息安全的同时满足性能要求。这一步骤的结果是可能的控制措施的列表,包括成本、效益和实施优先级。

选择和实施控制措施时宜考虑各种不同约束。典型考虑如下:

- 时间约束;
- 财务约束;
- 技术约束;
- 运行约束;
- 文化约束;
- 道德约束;
- 环境约束;
- 易用性;
- 人员约束;
- 集成新的和现有控制措施的约束。

关于风险降低约束的更多信息可参见附录 F。

9.3 风险保留

活动:应根据风险评估做出,在不采取进一步行动的情况下保留风险的决定。

实施指南:

如果风险水平符合风险接受标准,就不需要实施额外的控制,风险可以被保留。

9.4 风险规避

活动:应避免引起特定风险的活动或情况。

实施指南:

当所确定的风险被认为过高,或实现其他风险的处置方案的成本超过收益,可以决定,通过退出现有或计划中的活动或一组活动,或改变活动运行条件来完全规避风险。例如,对于由自然界引起的风险,将信息处理设施搬到风险不存在或处于控制之下的地方是最好的办法。

9.5 风险转移

活动:宜将风险转移给可以根据风险评估有效地管理特定风险的另一方。

实施指南:

风险转移涉及与外部各方共担某些风险的决策。风险转移能产生新的风险或更改现存的、已识别的风险。因此,额外的风险处置可能是必要的。

转移的实现可以通过保险来补偿后果,或者分包给合作伙伴来监视信息系统和立即采取行动阻止攻击以防造成超过规定程度的损害。

应当指出,转移管理风险的责任是可能的,但是转移影响的责任通常是不可能的。客户通常会将负面影响归于组织的过错。

10 信息安全风险验收

输入:风险处理计划和组织管理者决定接受的剩余风险评估。

活动:做出决定承担风险和责任的决定并正式记录。

实现指导:

风险处理计划应描述如何处理评估的风险以满足风险接受准则(见 7.2)。重要的是,负责的管理者要审查和批准建议的风险处理计划和产生的剩余风险,并记录与批准相关的任何条件。

风险接受准则可能比仅仅确定剩余风险是否超过或低于单一阈值更为复杂。

在某些情况下,剩余风险水平不符合风险接受准则,因为所采用的准则没有考虑到当时的情况。例如,因为风险带来的好处是非常有吸引力的,可以认为接受风险是必要的,或者因为降低风险的成本太高。这种情况表明,风险接受准则不够充分,如果可能,应加以修订。然而,并不总是能够及时修改风险接受准则。在这种情况下,决策者可以接受不符合正常接受准则的风险。如果这是必要的,决策者应该明确地对风险进行评价,并为推翻正常的风险接受准则的决定提供理由。

输出:包括那些不符合组织正常风险接受准则但带有可接受理由的可接受风险列表。

11 信息安全风险的沟通协商

输入:从风险管理活动中获得的所有风险信息(参见图 2)。

活动:关于风险的信息应该在决策者和其他利益相关方之间进行交换和/或共享。

实施指南:

风险沟通是通过决策者和其他利益相关方之间交换和/或共享关于风险的信息,就如何管理风险达成一致的活动。这些信息包括但不限于风险的存在、性质、形式、可能性、严重性、处置和可接受性。

利益相关方之间的有效沟通非常重要，因为这可能对要做出的决策产生重大影响。沟通确保那些负责实施风险管理的人，以及那些有既得利益的人理解做出决策的基础，以及为什么需要采取特定行动。沟通是双向的。

由于与风险或讨论中的问题有关的假设、概念和利益相关者的需要、问题和关注面的差异，对风险的认识可能会有所不同。利益相关方很可能根据风险的感知来判断风险的可接受性。这对于确保利益相关方对风险的感知以及他们对利益的感知能够被识别和记录，而且深层原因能够被清楚理解和解决，尤其重要。

应进行风险沟通，以便：

- 确保组织风险管理的结果；
- 收集风险信息；
- 分享风险评估结果并提出风险处理计划；
- 避免或减少因决策者和利益相关方之间缺乏相互了解而导致的信息安全漏洞的发生和后果；
- 支持决策制定；
- 获取新的信息安全知识；
- 与其他各方协调并计划应对措施，以减少任何事件的后果；
- 让决策者和利益相关方对风险有责任感；
- 提高认识。

一个组织应该为正常运行和紧急情况制定风险沟通计划。因此，风险沟通活动应持续进行。

主要决策者和利益相关方之间的协调可以通过成立一个委员会来实现，在该委员会中就可以就风险、优先级和适当处理以及接受进行讨论。

与组织内适当的公共关系或通讯部门合作以协调所有与风险沟通有关的任务是很重要的。例如，在应对特定事件的危机传播行动中，这是至关重要的。

输出：持续了解组织的信息安全风险

12 信息安全风险监测与评价

12.1 风险因素的监测与评价

输入：从风险管理活动中获得的所有风险信息（见图2）。

活动：应监测和评价风险及其因素（即资产的价值、影响、威胁、脆弱性、发生的可能性），以便在早期阶段识别组织环境中的任何变化，并保持对整个风险状况的概述。

实施指南：

风险不是静态的。威胁、脆弱性、可能性或后果可以突然改变而没有任何迹象。因此，需要不断的监测来检测这些变化。这可以由提供关于新威胁或脆弱性的信息的外部服务来支持。

组织应确保以下各项得到持续监测：

- 已纳入风险管理范围的新资产；
- 对资产价值进行的必要的修改，例如由于业务需求的改变；
- 新的威胁，可以是积极的，无论是在组织内外，还没有被评价；
- 新的或增加的脆弱性可能允许威胁利用这些新的或改变的脆弱性；
- 识别，确定那些暴露于新的或重新出现的威胁的脆弱性；
- 被评价的威胁、脆弱性和风险在聚合中影响或后果的增加，导致不可接受的风险水平；
- 信息安全事故。

新的威胁、脆弱性或可能性或后果的变化可以增加先前被评定为低风险的风险。对低风险和已接受风险的评审应分别考虑每个风险，以及所有这些风险作为一个集合，以评估其潜在的累积影响。如果风险不

属于低风险或可接受的风险类别，则应使用第9章所考虑的一种或多种选择来对待它们。

影响威胁发生的可能性和后果的因素可以改变，影响各种处置方案的适用性或成本的因素也可以改变。影响组织的重大变化应该是理性的更具体的评审。因此，应定期重复风险监测活动，并应定期评审所选择的处置方案。

风险监控活动的结果可以输入到其他风险评审活动中。组织应定期和在发生重大变化时评审所有风险。

输出：将风险管理与组织的业务目标和风险接受准则持续协调一致。

12.2 风险管理的监控、评审和改进

输入：从风险管理活动中获取的所有风险信息（见图2）。

活动：信息安全风险管理过程应当根据需求和适当地持续监测、评审和改进。

实施指南：

为了确保环境、风险评估和风险处理的结果以及管理计划与具体情况保持相关和适当，必须进行持续的监测和评审。

组织应确保信息安全风险管理过程和相关活动在当前情况下保持适当并得到遵守。任何商定的对过程的改进或改进对过程的符合性所必需的行动都应通知适当的管理者，以确保：

- 没有风险或风险因素被忽视或低估；
- 采取必要的行动；和
- 做出决策以提供现实的风险理解和响应能力。

此外，组织应定期验证用于测量风险及其因素的准则是否有效，并与业务目标、战略和方针一致。它还应该定期验证在信息安全风险管理过程中是否充分考虑了业务环境的更改。这一监测和评审活动应针对（但不限于）：

- 竞争环境；
- 风险评估方法；
- 资产价值和类别；
- 影响准则；
- 风险评估准则；
- 风险接受准则；
- 拥有的总成本；
- 必要的资源。

组织应确保不断提供风险评估和风险处理资源，以评审风险，处理新的或变化的威胁或脆弱性，并据此向管理层提出建议。

风险管理监控可能导致修改或添加途径、方法或工具。

取决于：

- 确定的变化；
- 风险评估迭代；
- 信息安全风险管理过程的目标（例如业务连续性、对事件的应变能力、合规性）；和
- 信息安全风险管理过程的对象（例如，组织、业务单元、信息处理、其技术实现、应用、互联网连接）。

输出：信息安全风险管理过程与组织的业务目标或过程更新持续协调一致。

附录 A

(资料性)

信息安全风险管理过程的范围和边界的确定

A.1 对组织的调研

组织评价:对组织的调研重新认识定义组织特性的特征要素。这关系到本组织的宗旨、业务、使命、价值和战略。这些要素应与有助于其发展的因素(例如分包)一起加以确定。

这种活动的困难在于确切地理解组织是如何构造的。确定其实际结构有助于了解每个部门在实现组织目标方面的作用和重要性。

例如,信息安全管理者向最高管理者而不是 IT 管理者报告的事实可以表明最高管理者参与了信息安全。

组织的主要目的:组织的主要目的可以定义为组织存在的理由(其活动领域、市场细分等)。

其业务:由其雇员的技术和专门知识所定义的组织业务,使其能够完成其使命。它具体到组织的活动领域,经常定义其文化。

它的使命:组织通过完成它的使命来达到它的目的。为确定其使命,应识别为最终用户所提供的服务和/或制造的产品。

它的价值:价值是应用于业务活动的主要原则或明确的行为准则。这可能关系到人员、与外部机构(客户等)的关系、所提供产品或服务的质量。

例如,以提供公共服务为目的,以运输为业务,以送孩子上学和放学为使命的组织,其价值可能是服务中准时和运输中的安全。

组织结构:有不同类型的结构。

——部门结构:每个部门置于负责其所在部门的战略、行政和业务决策的部门管理者的职权之下

——职能结构:是对程序、工作性质,有时是对决策或计划(例如生产、IT、人力资源、营销等)行使的职能权力。

注:

——具有部门结构的组织内部的部门可以作为职能结构进行组织,反之亦然。

——如果一个组织具有两种结构的元素,就可以说它具有矩阵结构。

——在任何组织结构中,可划分如下层级:

——决策层(战略方向的定义);

——领导层(协调和管理);

——运行层(生产和支持活动)。

组织结构图:组织结构在组织结构图中示意性地表示。这种表示应该突出报告的途径和授权的范围,但也应该包括其他关系,即使它们不基于任何正式授权,这些关系仍然是信息流的途径。

组织的战略:这需要正式表达组织的指导原则。组织的战略决定了从事重大的问题和它所计划的重大变化中受益所需的方向和发展。

A.2 影响组织的越苏因素清单

应考虑到影响组织和决定其信息安全方向的所有约束。它们的来源可以在组织内部(在这种情况下,它可以控制它们),也可以在组织之外,因此,通常是不可协商的。资源约束(预算、人员)和紧急约束是最重

要的。

组织将其确定的目标（涉及其业务、行为等）付诸特定的路径，可能会持续很长一段时间。

它定义了它想要成为什么，以及需要实现的手段。在指定此路径时，组织考虑技术和专门知识的发展、用户和客户表达的愿望等。这一目标可以用诸如削减经营成本，提高服务质量等为目的的经营或发展战略的形式来表示。

这些策略可能包括信息和信息系统（IS），它们有助于这些策略的应用。因此，有关组织的特性、任务和战略是分析问题的基本要素。因为信息安全方面的破坏可能导致重新考虑这些战略目标。此外，信息安全要求的建议必须与本组织现行的规则、使用的手段保持一致。

约束列表包括但不限于：

——政策性约束：这些可能涉及政府行政部门、公共机构或更一般地涉及任何实施政府决定的组织。它们通常是由政府部门或决策机构做出的关于战略或业务方向的决定，应当予以应用。

例如，发票或行政文件的计算机化引入了信息安全问题。

——战略性约束：约束可能产生于组织结构或方向上的计划的或可能的变化。它们被表达在组织的战略或运行计划中。

例如，在共享敏感信息方面的国际合作可能需要关于安全交换的协定。

——领土性约束：组织的结构和/或目的可能带来具体的约束，例如地点在整个领土或海外的分布。

例如，邮政服务、大使馆、银行、大型工业集团的附属公司等。

——由经济和政治气候产生的约束：组织的运作可因诸如罢工或国家和国际危机等具体事件而深刻改变。

例如，即使在严重危机期间，一些服务也应该能够继续。

——结构约束：组织结构（部门、功能或其他）的性质可能导致一个适应该结构的特定的信息安全策略和安全组织。

例如，国际结构应该能够协调每个国家特有的安全要求。

——功能约束：功能约束直接来自组织的一般使命或特定使命。

例如，24 小时运作的组织应该确保其资源持续可用。

——人员方面的约束：这些约束的性质差别很大。它们与责任层级、招聘、资格、培训、安全意识、动机、可用性等相关。

例如，国防组织的全体人员都应该有权处理高度机密的信息。

——由组织日程表引起的约束：这些约束可能是由于改组或制定新的政策规定某些最后期限造成的。

例如，安全部门的创建。

——与方法相关的约束：适合组织专有技术的方法需要强行施加在项目策划、规范、开发等方面。

——文化性质的约束：在一些组织中，工作习惯或主要业务导致了组织内的特定“文化”，这可能与安全控制不兼容。这种文化是员工的一般参考框架，可以由教育、教学、专业经验、工作以外的经验、观点、哲学、信仰、社会地位等多方面决定。

——预算约束：建议的安全控制有时会有很高的成本。虽然将安全投资建立在成本效益的基础上并不总是恰当的，但组织的财务部门通常需要经济理由。

例如，在私营部门和一些公共组织中，安全控制的总成本不应超过风险的潜在后果的成本。因此，如果最高管理层想要避免过高的安全成本，就应该评估并承担经过计算的风险。

A.3 影响范围的限制条件列表

通过识别约束，可以列出那些对范围有影响的约束，并确定哪些约束仍然需要采取适当的行动。

它们被添加到上面确定的组织约束中，并且可能会修改这些约束。

以下各段列出了一些可能的约束类型。

由预先存在的过程引起的约束

应用程序项目不一定同时开发。有些依赖于预先存在的过程。即使一个过程可以被分解成子过程，这个过程也不一定会受到另一个过程的所有子过程的影响。

技术约束

与基础设施有关的技术约束通常来自已安装的硬件和软件，以及存放过程的空间或位置：

- 文件(关于组织要求、媒体管理要求、访问规则管理要求等)；
- 总体结构[关于拓扑结构(集中式、分布式、客户端-服务器)、物理结果等的要求]；
- 应用软件(具体软件设计、市场标准等要求)；
- 套装软件(关于标准、评价级别、质量、遵守规范、安全等方面的要求)；
- 硬件(有关标准、质量、遵守规范等方面的要求)；
- 通信网络(涉及范围、标准、容量、可靠性等要求)；
- 建筑基础设施(土建、施工、高电压、低电压等要求)。

金融约束

安全控制的实施通常受到组织可以承诺的预算的约束。然而，财务约束仍然应该是最后一个被考虑的，因为安全预算分配可以在安全研究的基础上进行协商。

时间约束

实施安全控制所需的时间应考虑到信息系统升级的能力；如果实施时间很长，那么设计控件的风险可能已经改变。时间是选择解决方案和优先级的决定因素。

与方法相关的约束

适合组织的专有技术的方法应该用于项目规划、规范、开发等等。

组织的约束

各种约束可以遵循如下组织需求：

- 运营(交付时间、服务供应、监督、监测、应急预案、降级运营等要求)；
- 维护(故障排除、预防措施、快速纠正等要求)；
- 人力资源管理(操作员和用户培训要求、系统管理员或数据管理员等职位的资格要求)；
- 行政管理(职责要求等)；
- 开发管理(开发工具、计算机辅助软件工程、验收计划、组织设置等要求)；
- 外部关系管理(有关第三方关系、合同等组织的要求)。

附件 B

(资料性)

资产的识别与评估及影响评估

B.1 资产识别实例

B.1.1 总则

为了实施资产评估，组织首先需要识别其资产（在适当的细节层次）。有两种资产可以区分：

- 主要资产：
 - 业务流程和活动；
 - 信息；

——所有类型的（其范围的主要元素所依赖的）支持资产：

- 硬件；
- 软件；
- 网络；
- 人员；
- 站点；
- 组织结构。

B.1.2 主要资产的识别

为了更准确地描述范围，这个活动包括识别主要资产（业务流程和活动，信息）。这种识别由代表该过程的混合工作组（管理者、信息系统专家和用户）进行。

主要资产通常是活动范围内的核心过程和信息。还可以考虑其他主要资产，例如组织的流程，这些资产更适合于制定信息安全策略或业务连续性计划。根据目的，一些研究不需要对构成范围的所有要素进行详尽的分析。在这种情况下，研究范围可以局限于范围的关键元素。

主要资产有两种类型：

1) 业务流程（或子过程）和活动，例如：

- 过程的损失或退化使其无法执行组织的使命；
- 含有秘密的过程或涉及专有技术的过程；
- 如果修改，会极大地影响组织使命的完成的过程；
- 组织遵守根据第6章确定的适用的合同、法律或管理要求所必需的过程。

2) 信息。一般而言，主要信息包括：

- 为执行本组织的使命或业务而提供的重要信息；
- 个人信息，可在有关隐私的国家法律中明确定义；
- 为实现战略方向所确定的目标所需的战略信息；
- 高成本的信息，其收集、存储、处理和传输需要较长时间和/或涉及较高的获取成本。

在本活动之后未被识别为敏感过程和信息的是在本调研的其余部分中不必定义分类。这意味着，即使这些过程或信息受到损害，本组织仍然能够成功地完成任务。但是，它们通常获得实施以保护被识别为敏感的过程和信息的控制。

B.1.3 支持资产的清单和描述

范围包括应识别和描述的资产。这些资产存在可被旨在损害范围（流程和信息）的主要资产的威胁所利用的脆弱性。它们有多种类型：

——硬件。硬件由支持过程的所有物理元素组成。

——数据处理设备（主动式）：自动信息处理设备，包括独立操作所需的项目。

——可移动设备：便携式计算机设备。

例如：笔记本电脑，个人数字助理（PDA）。

——固定设备：在组织的场所使用的计算机设备。

例如：服务器，作为工作站使用的微型计算机。

——外围处理设备：通过通信端口（串行、并行链路等）与计算机连接的用于输入、传送或传输数据的设备。

例如：打印机，可移动磁盘驱动器。

——数据介质（被动）：存储数据或函数的介质。

——电子介质：可连接到计算机或计算机网络进行数据存储的信息介质。尽管它们的紧凑的大小，

这些媒体可以包含大量的数据。它们可以与标准的计算设备一起使用。

例如：软盘、光盘、备份盒、可移动硬盘、存储键、磁带。

——其他媒体：包含数据的静态、非电子媒体。

例如：纸张、幻灯片、透明度、文档、传真。

——软件：软件由所有有助于数据处理集操作的程序组成。

——操作系统：包括构成运行所有其他程序（服务或应用程序）的操作基础的计算机的所有程序。它包括内核和基本功能或服务。根据体系结构，操作系统可以是单片的或由微内核和一组系统服务组成的。操作系统的主要元素是所有设备管理服务（CPU、内存、磁盘和网络接口）、任务或过程管理服务和用户权限管理服务。

——服务、维护或管理软件：软件的特点是它补充了操作系统服务，而不是直接为用户或应用程序服务（尽管它通常是信息系统的全球操作所必需的，甚至是不可缺少的）。

——套装软件或标准软件：标准软件或套装软件是商业化（而不是一次性或特定的开发）的具有介质、发布和维护的完整产品。它们为用户和应用程序提供服务，但不像业务应用程序那样个性化或特定。

例如：数据库管理软件、电子消息传递软件、群件、目录软件、web 服务器软件等。

——业务应用程序：

——标准业务应用：这是一种商业软件，目的是让用户能够直接从他们的信息系统中获得他们在专业环境中需要的服务和功能。有一个非常广泛的，理论上是无限的领域。

例如：会计软件、机床控制软件、客户服务软件、人员能力管理软件、管理软件等。

——具体业务应用：这是一种软件，其中的各个方面（主要是支持、维护、升级等）都是专门为用户开发的。使用户可以直接从他们的信息系统中访问他们需要的服务和功能。有一个非常广泛的，理论上无限的领域。

例如：电信运营商客户发票管理，火箭发射实时监控应用。

——网络：网络由用于互连多个物理远程计算机或信息系统元素的所有电信设备组成。

——媒介和支持：通信和电信媒介或设备主要以设备的物理和技术特性（点对点、广播）和通信协议（链路或网络—OSI 7 层模型的第 2 和 3 层）为特征。

例如：公共交换电话网络（PSTN）、以太网、千兆以太网、不对称数字用户线（ADSL）、无线协议规范（例如，WiFi 802.11）、蓝牙、FireWire。

——被动或主动中继：该子类型包括所有不是通信逻辑终端（IS 视觉），而是中间或中继设备的设备。中继器的特点是支持网络通信协议。除了基本的中继之外，它们通常还包括路由和/或过滤功能和服务，使用带有过滤器的通信交换机和路由器。它们通常可以远程管理，并且通常能够生成日志。

例如：网桥、路由器、集线器、交换机、自动交换。

——通信接口：处理单元的通信接口连接到处理单元，但具有媒体和支持协议。任何已安装的过滤、日志或警告生成功能及其容量、远程管理的可能性和需求等特点。

例如：通用分组无线业务（GPRS）、以太网适配器。

——人员：人员由信息系统中涉及的所有人群组成。

——决策者：决策者是主要资产（信息和功能）的所有者，是组织或特定项目的管理者。

例如：最高管理者、项目负责人。

——用户：用户是在其活动范围内处理敏感要素并在这方面负有特殊责任的人员。他们可以对信息系统有特殊的访问权限来执行他们的日常任务。

例如：人力资源管理、财务管理、风险管理等。

——操作/维护人员：负责操作和维护信息系统的人员。他们对信息系统有特殊的访问权限来执行他们的日常任务。

例如：系统管理员，数据管理员，备份/服务台/应用部署操作员，安全人员。

——开发人员：开发人员负责开发组织的应用程序。他们有权使用高权限的部分信息系统，但不生产数据采取任何行动。

例如：业务应用程序开发人员。

——场所：场所包括全范围或部分范围的所有位置，以及运行所需的物理方法。

——位置：

——外部环境：这涉及组织的安全手段无法应用的所有位置。

例如：人员，其他组织的辖区，场地外的环境（市区，危险区域）。

——辖区：这个地方的边界直接与外部接触。这可以通过在建筑物周围创建物理屏障或监视手段而获得的物理保护边界。

例如：企业，建筑物。

——区域：区域由在组织场所内形成分区的物理保护边界形成。它是通过在组织的信息处理基础设施周围创建物理障碍而获得的。

例如：办公室，限制访问区域，安全区域。

——基本服务：组织设备运行所需的所有服务。

——通信：电信运营商提供的电信服务和设备。

例如：电话线，PABX（程控交换机），内部电话网。

——公用设施：

——为信息技术设备和外围设备提供电力所需的服务和手段（电源和布线）。

例如：低压电源、逆变器、电路头端。

——供水

——废物处理

——冷却和净化空气的服务和手段（设备，控制）。

例如：冷却水管道，空调器。

——组织：组织描述组织框架，包括分配给任务的所有人员结构和控制这些结构的过程。

——权力机构：这些组织是被研究的组织获得权威的来源。它们可以是合法的分支机构，也可以是外部机构。这在规章条款、决定和行动方面对所研究的组织强加约束。

例如：管理机构，组织总部。

——组织结构：包括在其管理之下的本组织各部门，包括其跨职能活动。

例如：人力资源管理、IT 管理、采购管理、业务单元管理、楼宇安全服务、消防服务、审计管理。

——项目或系统组织：这关系到为特定项目或服务而建立的组织。

例如：新应用程序开发项目、信息系统迁移项目。

——分包商/供应商/制造商：这些组织向组织提供服务或资源，并通过合同与之绑定。

例如：设备管理公司，外包公司，咨询公司。

B.2 资产评估

B.2.1 总则

资产识别之后的下一步是商定要使用的尺度，以及基于估价用这个尺度为每个资产赋值的准则。由于

在大多数组织中发现的资产的多样性，有可能一些具有已知货币价值的资产以当地货币单位进行估价，而另一些具有更定性价值的资产可以分配一个范围，例如，从“非常低”到“非常高”。使用定量或定性尺度的决定实际上是一个组织偏好的问题，但是应该与所评估的资产相关。两种评估类型都可以用于同一资产。

用于资产定性估价的典型术语包括：可忽略的、非常低的、低的、中等的、高的、非常高的和关键的。适合组织的术语的选择和范围很大程度上取决于组织对安全性、组织规模和其他组织特定因素的需求。

B.2.2 准则

用作为每个资产赋值基础的准则应该用明确的术语写出来。

这通常是资产评估中最困难的方面之一，因为一些资产的价值可能必须被主观地确定，并且有许多不同的个人有可能做出决定。用于确定资产价值的可能准则包括其原始成本、其更换或再造成本或其可以是抽象的价值，例如组织的声誉价值。

资产估价的另一个基础是因事故造成的机密性、完整性和可用性损失而导致的成本。适当时，也应考虑不可抵赖性、责任性、真实性和可靠性。这种估价除了重置成本之外，还基于对由具有假设的一组情况的安全事故导致的不利业务后果的估计，为资产价值提供了重要的要素维度。需要强调的是，这种方法考虑了影响风险评估的必要性。

在估值过程中，许多资产可以赋予若干个值。例如，商业计划可以基于开发计划所花费的劳动力、输入数据的劳动力以及它对竞争对手的价值来估价。所分配的值最可能有很大差异。

赋值可以是所有可能值的最大值，也可以是部分或全部可能值的总和。在最终分析中，应仔细确定将赋予资产哪个或哪些值，因为最终赋值在确定用于保护资源的资源时起作用。

B.2.3 约化共基

最终，所有的资产估值都需要换算到共同的基础。

这可以通过一些准则来实现，这些准则可用于评估由于机密性、完整性、可用性、不可抵赖性、责任性、真实性或资产可靠性丧失而可能产生的后果，例如：

- 业务绩效的损害；
- 商誉损失对声誉的负面影响；
- 与个人信息相关的违规；
- 危及人身安全；
- 对执法的不利影响；
- 违反保密规定；
- 违反公共秩序；
- 财务损失；
- 业务活动中断；和
- 危及环境安全。

另一种评估后果的方法可以是：

- 中断服务；无法提供服务；
- 丧失客户信心；
- 丧失内部信息系统的可信性；和
- 名誉损害；
- 扰乱内部运作；
- 组织本身的破坏；和
- 附加内部成本；
- 破坏第三方的运作；

- 第三方与组织发生冲突；和
- 各种类型的伤害；
- 对人员/用户安全的危险：组织人员和/或用户的危险；
- 攻击用户的私生活；
- 财务损失；
- 紧急或修理的财务费用；
 - 在人员方面；
 - 在设备方面；以及
 - 在研究方面，专家报告；
- 货物/资金/资产的损失；
- 客户流失，供应商流失；
- 司法程序和处罚；
- 丧失竞争优势；
- 丧失工艺/技术领先；
- 丧失有效性/信任；
- 丧失技术声誉；
- 谈判能力弱化；
- 工业危机（罢工）；
- 政府危机；
- 解散；
- 材料损坏。

这些准则是资产评估要考虑的问题的示例。为了实施估值，组织需要选择与业务类型和安全要求相关的准则。这意味着上面列出的一些准则是不适用的，并且可以把其他的添加到列表中。

B.2.4 尺度

在确定要考虑的准则之后，组织应该商定在组织范围内使用的尺度。第一步是决定要使用的级别的数量。没有关于最合适级数的规则，更多的级别提供了更大的粒度级别，但有时过于精细的差别使得在整个组织中赋值一致性变得困难。通常，可以使用 3（例如，低、中、高）和 10 之间的任意数量的级别，只要它与组织用于整个风险评估过程的方法一致。

一个组织可以定义自己的资产价值限额，如“低”、“中等”或“高”。这些限额应根据所选择的准则来评估（例如，对于可能的财务损失，应以货币价值给出，但对于诸如危及人身安全之类的考虑，货币估价可能是复杂的，可能不适合所有组织）。最后，完全由组织决定什么被认为是“低”或“高”的后果。对于一个小的组织来说，灾难性的后果对于一个非常大的组织来说可能是低的甚至是可以忽略不计的。

B.2.5 依赖关系

资产支持的业务流程越是相关和越多，该资产的价值就越大。还应该识别资产对业务流程和其他资产的依赖性，因为这会影响资产的价值。例如，应在其整个生命周期，包括存储和处理在内的所有阶段保持数据的保密性，即数据存储和处理程序的安全需求应直接与表示存储和处理的数据的保密性的值相关。此外，如果业务流程依赖于由程序产生的某些数据的完整性，则该程序的输入数据应当具有适当的可靠性。此外，信息的完整性取决于其存储和处理所使用的硬件和软件。此外，硬件依赖于电源和可能的空调。因此，依赖关系的信息有助于识别威胁，特别是脆弱性。此外，它有助于确保资产的真实价值（通过依赖关系）被赋予资产，从而指示适当的保护级别。

其他资产依赖的资产价值可以通过以下方式修正：

- 如果依赖资产(例如数据)的价值低于或等于所考虑资产(例如软件)的价值，则其价值保持不变；
- 如果依赖资产(例如，数据)的值较大，则所考虑的资产(例如，软件)的价值应根据以下情况增加：
 - 依赖程度；
 - 其他资产的价值。

一个组织可以拥有一些不止一次可用的资产。比如软件程序的副本或者大多数办公室使用的相同类型的计算机。在进行资产评估时，考虑这一点是很重要的。一方面，这些资产很容易被忽视。因此，应注意识别它们。另一方面，它们可以用来减少可用性问题。

B.2.6 输出

此步骤的最终输出是资产及其与泄露（机密）、篡改（完整性、真实性、不可否认性和责任性）、不可用性和丧失（可用性和可靠性）以及更换成本有关的价值的列表。

B.3 影响评估

信息安全事件可以影响不止一种资产或仅仅是资产的一部分。影响与事件成功的程度有关。因此，资产价值与事件造成的影响之间存在着重要的差异。影响被认为是具有当前（运行）影响或未来（业务）影响，包括金融和市场后果。

当前（运行）影响或是直接的或是间接的。

1) 直接：

- a) 损失（部分）资产的金融重置价值；
- b) 购置、配置和安装新资产或备份的成本；
- c) 因事件而暂停经营的费用，直至资产提供的服务得以恢复；和
- d) 影响导致信息安全漏洞。

2) 间接的：

- a) 机会成本（替换或修理资产所需的财务资源将在别处使用）；
- b) 中断作业的成本；
- c) 通过安全漏洞获得的信息的潜在滥用；
- d) 违反法定或监管义务；和
- e) 违反道德行为准则。

因此，第一次评估（没有任何类型的控制）估计出一个（一组）非常接近有关的资产价值的影响。对于这个（这些）资产的任何下一次评估，由于所实现的控件的存在和有效性，影响是不同的（通常要低得多）。

附件 C

（资料性）

典型威胁实例

下表给出了典型威胁的示例。该列表可在威胁评估过程中使用。威胁可能是故意的，偶然的或环境的（自然的），并导致例如基本服务的损坏或丢失。以下列表显示了每种威胁类型，其中 D（故意），A（偶然），E（环境）是相关的。D 用于针对信息资产的所有蓄意行为，A 用于可能意外损坏信息资产的所有人为行为，E 用于所有不基于人为行为的事件。这些威胁并不是按照优先顺序排列的。

类型	威胁	来源
----	----	----

物理损伤	火灾	A, D, E
	水灾	A, D, E
	污染	A, D, E
	重大事故	A, D, E
	设备或介质毁坏	A, D, E
	灰尘, 腐蚀, 冻结	A, D, E
自然事件	气候现象	E
	地震现象	E
	火山现象	E
	气象现象	E
	洪水	E
基本服务丧失	空调或供水故障	A, D
	电源损耗	A, D, E
	通信设备故障	A, D
辐射干扰	电磁辐射	A, D, E
	热辐射	A, D, E
	电磁脉冲	A, D, E
信息干扰	干扰骚扰信号的截获	D
	远程间谍	D
	窃听	D
	窃取媒体或文件	D
	盗窃设备	D
	再生的或废弃的介质的回收	D
	泄露	A, D
	来自不可信来源的数据	A, D
	硬件篡改	D
	软件篡改	A, D
	位置检测	D
技术故障	设备失效	A
	设备故障	A
	信息系统的饱和	A, D
	软件故障	A
	信息系统的可维护性损坏	A, D
未经授权的行动	擅自使用设备	D
	软件欺诈复制	D
	伪造或盗版软件的使用	A, D
	数据破坏	D
	非法处理数据	D
功能损伤	使用中的错误	AA

	滥用职权	A、D
	权利伪造	D
	否认行为	D
	破坏人员可用性	A、D、E

应特别注意人为威胁源。这些内容具体列在下表中：

威胁的起源	动机	可能的后果
黑客、解密高手	挑战 自我 叛乱 地位 金钱	——黑客攻击 ——社会工程 ——系统入侵、中断 ——未经授权的系统访问
计算机犯罪	信息破坏 非法信息披露 货币收益 未经授权的数据变更	——计算机犯罪（如网络追踪） ——欺诈行为（例如重演、模仿、拦截） ——信息贿赂 ——欺骗 ——系统入侵
恐怖分子	勒索 破坏 盘剥 复仇 政治收益 媒体报道	——炸弹/恐怖主义 ——信息战 ——系统攻击（例如分布式拒绝服务） ——系统渗透 ——系统篡改
工业间谍活动 （情报、公司、 外国政府、其他 政府利益）	优势竞争 经济间谍活动	——国防优势 ——政治优势 ——经济利用 ——信息窃取 ——侵犯个人隐私 ——社会工程 ——系统渗透 ——未经授权的系统访问（访问机密的、专有的和/或技术相关的信息）
内部人士（训练 有素，不满，恶 意，疏忽，不诚 实，或终止雇员）	好奇 自我 智力 货币收益 复仇 无意的错误和泄漏（例如数 据录入错误，编程错误）	——殴打雇员 ——敲诈 ——浏览专有信息 ——电脑滥用 ——欺诈和盗窃 ——信息贿赂 ——篡改、损坏数据的输入 ——拦截 ——恶意代码（例如病毒、逻辑炸弹、特洛伊木马）

		——个人信息销售 ——系统错误 ——系统入侵 ——系统破坏 ——未经授权的系统访问
--	--	---

附录 D

(资料性)

脆弱性和脆弱性评估方法

D.1 脆弱性示例

下表给出了各种安全领域中的脆弱性的示例，包括可以利用这些脆弱性的威胁的示例。列表可以在评估威胁和脆弱性时提供帮助，以确定相关的事件场景。需要强调的是，在某些情况下，其他威胁也可以利用这些脆弱性。

类型	脆弱性示例	威胁示例
硬件	存储介质维护不足/故障安装	信息系统的可维护性
	缺乏定期更换方案	设备或介质的破坏
	对潮湿、灰尘、污物的敏感性	灰尘、腐蚀、冻结
	电磁辐射敏感性	电磁辐射
	缺少有效的配置变更控制	使用错误
	电压变化敏感性	电源损坏
	温度变化敏感性	气象现象
	无保护存储器	窃取媒体或文件
	处置不力	窃取媒体或文件
	无控制复制	窃取媒体或文件
软件	没有或不充分的软件测试	权利滥用
	众所周知的软件缺陷	权利滥用
	离开工作站时没有“注销”	权利滥用
	没有适当擦除的存储介质的处理或再利用	权利滥用
	缺乏审计线索	权利滥用
	访问权限分配不当	权利滥用
	广泛分布的软件	数据破坏
	应用程序在错误数据中的应用	数据破坏
	复杂用户界面	使用错误
	文献缺乏	使用错误
	错误参数设置	使用错误
	不正确日期	使用错误
	缺乏身份验证和认证机制，比如用户认证	权利伪造

	无保护密码表	权利伪造
	密码管理不良	权利伪造
	启用不必要服务	非法处理数据
	不成熟的或新的软件	软件故障
	开发人员不明确或不完整的规范	软件故障
	缺乏有效的变更控制	软件故障
	软件的无控制下载与使用	篡改软件
	备份备份不足	篡改软件
	缺乏建筑、门窗的物理保护	窃取媒体或文件
	未能制作管理报告	擅自使用设备
网络	缺少发送或接收消息的证据	否认行为
	通信线路无保护	窃听
	敏感通信无保护	窃听
	电缆接头不良	通信设备故障
	单点故障	通信设备故障
	缺少发送者和接收者的识别和认证	权利伪造
	不安全网络体系结构	远程间谍
	口令明码传输	远程间谍
	网络管理不足（路由弹性）	信息系统的饱和
	无保护的公共网络连接	擅自使用设备
人员	人员缺位	违反人员可用性
	招聘程序不足	设备或介质的破坏
	安全培训不足	使用错误
	软件和硬件的错误使用	使用错误
	缺乏安全意识	使用错误
	缺乏监督机制	非法处理数据
	外部或清洁人员的非监督工作	窃取媒体或文件
	缺乏正确使用电信媒体和消息的政策	擅自使用设备
场所	对建筑物和房间的物理访问控制不适当或不到位	设备或介质的破坏
	易受洪水影响的地区	水灾
	不稳定电网	电源损害
	缺乏建筑、门窗的物理保护	设备被盗
	缺少用户注册和取消注册的正式程序	权利滥用
	缺乏正式的访问权限审查程序（监督）	权利滥用
	与客户和/或第三方合同的缺乏或有关规定（涉及安全）	权利滥用
	缺乏信息处理设施的监控程序	权利滥用
	缺乏定期审计（监督）	权利滥用
	缺乏风险识别和评估程序	权利滥用

缺少管理员和操作员日志记录的故障报告	权利滥用
服务维护响应不足	损坏信息系统的可维护性
服务级别协议不足或不足	损坏信息系统的可维护性
缺少变更控制程序	损坏信息系统的可维护性
缺乏规范化的 ISM 文件控制程序	数据破坏
缺乏正式的 ISM 记录程序	数据破坏
公共可用信息授权的正式程序缺乏	来自不可信来源的数据
信息安全责任分配不当	否认行为
缺乏连续性计划	设备故障
缺少电子邮件使用方针	使用错误
缺乏将软件引入操作系统的程序	使用错误
缺少管理员和操作员日志记录	使用错误
缺乏分类信息处理程序	使用错误
工作描述中信息安全责任的缺失	使用错误
与雇员订立合同有关规定的欠缺或不充分	非法处理数据
在信息安全事件中缺乏明确的纪律处分程序	盗窃设备
缺乏对移动计算机使用的正式方针	盗窃设备
对非经营性资产缺乏控制	盗窃设备
“清空桌面和清空的屏幕”方针缺乏或不足	窃取媒体或文件
缺乏信息处理设施	窃取媒体或文件
缺乏安全漏洞的监控机制	窃取媒体或文件
缺乏定期的管理评审	擅自使用设备
缺乏报告安全薄弱环节的程序	擅自使用设备
缺乏符合知识产权规定的程序	伪造或盗版软件的使用

D.2 评估技术脆弱性的方法

根据信息和通信技术 (ICT) 系统的重要性和以及用资源（例如分配的资金、可用的技术，具有进行测试的专门知识的人），可以使用诸如信息系统测试之类的主动方法来识别脆弱性。

测试方法包括：

- 脆弱性自动扫描工具；
- 安全测试和评估；
- 渗透测试；
- 代码审查。

脆弱性自动扫描工具用于扫描一组主机或网络，用于已知的易受攻击的服务（例如，系统允许匿名文件传输协议 (FTP)、Sieve 中继）。然而，应当注意，自动扫描工具所识别的一些潜在脆弱性可能不代表系统环境中的真实脆弱性。例如，这些扫描工具中的一些在不考虑站点的环境和要求的情况下对潜在的脆弱性进行评级。自动扫描软件识别的一些脆弱性实际上可能对某个特定站点并不脆弱，但是可以以这种方式配置，因为它们的环境需要它。因此，这种测试方法可以产生误报。

安全测试和评估 (STE) 是另一种技术，可用于在风险评估过程中识别 ICT 系统脆弱性。它包括测试计划的开发和实施（例如测试脚本、测试程序和预期的测试结果）。系统安全测试的目的是测试在操作环境中

应用的 ICT 系统的安全控制的有效性。其目标是确保所应用的控制满足批准的软件和硬件安全规范，并执行组织的安全策略或满足行业标准。

渗透测试可以用来补充对安全控制的审查，并确保确保信息和通信技术系统的不同方面的安全。渗透测试，当用于风险评估过程中，可以用来评估 ICT 系统的能力，以抵御故意企图规避系统安全。其目的是从威胁源的角度测试 ICT 系统，并识别 ICT 系统保护方案中的潜在故障。

代码审查是最脆弱的（但也是最昂贵的）脆弱性评估方法。

这些类型的安全测试的结果将有助于识别系统的脆弱性。

重要的是要注意，除非成功利用脆弱性，否则渗透工具和技术可能给出错误的结果。为了开发特定的脆弱性，需要了解测试系统上的精确系统/应用程序/补丁设置。如果在测试时不知道这些数据，可能无法成功利用特定的脆弱性（例如，获得远程反向 shell）；但是，仍然可能崩溃或重新启动测试的进程或系统。在这种情况下，测试对象也应该被认为是脆弱的。

方法包括下列活动：

- 面试人员和用户；
- 问卷调查；
- 身体检查；
- 文档分析。

附录 E

（资料性）

信息安全风险评估方法

E.1 高层信息安全风险评估

高层评估允许定义行动中的优先顺序和年表。由于各种原因，例如预算，不可能同时实施所有控制，并且只有最关键的风险可以通过风险处理过程进行处理。同时，如果仅仅在一两年后才开始实施，那么开始详细的风险管理还为时过早。为了实现这一目标，高层评估可以从对后果的高层评估开始，而不是从对威胁、脆弱性、资产和后果的系统分析开始。

从高层评估开始的另一个原因是与变更管理（或业务连续性）相关的其他计划同步。例如，如果计划在不久的将来将系统或应用程序外包，则完全保护系统或应用程序是不合理的，尽管为了定义外包合同仍然值得进行风险评估。

高层评估迭代的特征可以包括以下内容：

——高层风险评估可以关注该组织及其信息系统的更加全局的一面，独立于业务地考虑技术方面问题。通过这样做，环境分析更多地集中在业务和运行环境上，而不是技术因素。

——高层风险评估可以关注属于指定领域的更有限的威胁和脆弱性列表，或者为了加速该过程，它可以将重点放在风险或攻击场景而不是它们的要素上。

——在高层风险评估中面对的往往是比特定识别的风险更普遍的风险领域。当场景或威胁在域中成组时，风险处理提供域中的控制列表。风险处理活动首先尝试提出并选择在整个系统中有效的共同控制。

——然而，高层风险评估由于很少涉及技术细节，因此更适合于提供组织的和非技术的控制和技术控制的管理方面，或者提供关键和共同的技术保障，例如备份和反病毒。

高层风险评估的益处如下：

- 初始简单方法的合并很可能得到风险评估方案的接受。

- 应该能够建立组织信息安全方案的战略图景，作为一个很好的规划辅助。
- 可在最有效益的地方应用资源和资金，并首先解决可能最需要保护的系统。

由于初始风险分析处于较高层级，而且可能更不准确，因此唯一的潜在缺点是，某些业务流程或系统可能不被识别为需要第二次详细的风险评估。如果组织及其信息和系统的所有方面都有足够的信息，包括从信息安全事件的评估中获得的信息，则可以避免这种情况。

高层风险评估关注信息资产的业务价值，以及从组织的业务角度考虑风险。在第一个决策点（参见图 2），有几个因素有助于确定高层评估是否足以处理风险；这些因素可以包括下列因素：

- 通过使用各种信息资产实现的业务目标；
- 组织的业务在多大程度上取决于每个信息资产，即组织认为对其生存或业务有效开展至关重要的因素是依赖于每项资产，还是依赖于机密性、完整性、可用性、不可否认性、责任性。此资产存储和处理的信息的真实性和可靠性；
- 在开发、维护或替换资产方面，每种信息资产的投资水平；和
- 组织直接赋予价值的信息资产。

当评估这些因素时，决策就变得容易了。如果资产的目标对于组织的业务行为极其重要，或者如果资产处于高风险，那么应当针对特定信息资产（或其一部分）进行第二次迭代，即详细的风险评估。

要应用的一般规则是：如果信息安全的缺乏可能对组织、其业务流程或其资产造成重大的不利后果，那么有必要在更详细的层次上进行第二次迭代风险评估，以识别潜在的风险。

E.2 详细信息安全风险评估

E.2.1 总则

详细信息安全风险评估过程包括深入识别和评估资产、评估这些资产的威胁以及评估脆弱性。然后从这些活动的结果来评估风险，然后确定风险处置。

详细的步骤通常需要相当多的时间、精力和专门知识，因此最适合于高风险的信息系统。

详细信息安全风险评估的最后阶段是评估总体风险，这是本附件的重点。

结果可以用几种方式评估，包括使用定量，例如货币，和定性（这可以基于形容词，如中度或严重），或两者的组合度量。为了评估威胁发生的可能性，应该建立资产赋值或需要保护的时间框架。发生特定威胁的可能性受以下影响：

- 资产的吸引力或可能的影响，在考虑有预谋的人为威胁时适用；
- 利用资产的脆弱性容易转换为奖励，如果考虑蓄意的人为威胁则适用；
- 威胁代理的技术能力，适用于蓄意的人类威胁；
- 脆弱性的易受攻击性，适用于技术性和非技术性的脆弱性。

许多方法利用表格，并结合主观和客观的测量。重要的是，组织要使用一种它感到舒适、有信心并产生可重复结果的方法。下面给出了基于表格的技术的几个示例。

有关可用于详细信息安全风险评估的技术的附加指南，请参见 IEC 31010。

下面的例子使用数字来描述定性评估。这些方法的使用者应该意识到，使用由定性风险评估方法产生的定性结果的数字来执行进一步的数学操作可能是无效的。

E.2.2 示例 1 具有预定义值的矩阵

在这种类型的风险评估方法中，实际或拟议的实物资产按置换或重建成本来估价（即定量测量）。然后将这些成本转换为与信息使用相同的定性尺度（见下文）。

实际或建议的软件资产以与实际资产相同的方式估价，识别出购买或重建成本，然后转换成与用于信息估价的同类尺度。此外，如果发现任何应用软件对机密性或完整性具有其自身的内在要求（例如，如果

源代码本身在商业上是敏感的)，则其价值与信息价值相同。

信息的价值是通过访问选定的可以权威地谈论数据的业务管理层(数据所有者)而获得的，以确定实际使用的或将要存储、处理或访问的数据的价值和敏感性。

访谈有助于根据最坏情况评估信息的价值和敏感性，最坏情况可能是由于未经授权的披露、未经授权的修改、不同时间段的不可用性和毁灭造成的合理预计会发生的不利业务后果。

估值是利用信息评估准则完成的，该准则涵盖了如下问题：

- 人身安全；
- 个人信息和隐私；
- 执法；
- 商业和经济利益；
- 财务损失/活动中断；
- 公共秩序；
- 业务方针和运作；
- 丧失商誉；和
- 与客户签订合同或协议。

这些指导方针有助于在数字尺度上识别值，例如下面示例矩阵中所示的 0 到 4 个尺度，从而能够识别可能的和逻辑的定量值，以及不可能有定量值的定性值，例如危及人类生命。

下一个主要活动是完成针对每个威胁类型以及与威胁类型相关的每组资产的成对的调查问卷，以便能够评估威胁的级别（发生的可能性）和脆弱级别（易受威胁的利用造成不良后果的难易程度级别），每个问答都能得分。这些分数是通过知识库积累的，并与范围进行比较。这识别了例如从高到低级别的威胁级别和脆弱性级别。类似地，如下面的示例矩阵所示，区分相关的后果类型。完成问卷的信息应从与适当的技术、人员和后勤人员的访谈、实际地点检查和文件审查中收集。

与每种类型的后果相关的资产价值以及威胁和脆弱性水平在如下所示的矩阵中匹配，以便为每种组合确定 0 至 8 级的相关风险度量。这些值以结构化方式放置在矩阵中。下面给出一个例子：

表 E.1

威胁发生的可能性		低			中			高		
脆弱性易被利用性		低	中	高	低	中	高	低	中	高
资产价值	0	0	1	2	1	2	3	2	3	4
	1	1	2	3	2	3	4	3	4	5
	2	2	3	4	3	4	5	4	5	6
	3	3	4	5	4	5	6	5	6	7
	4	4	5	6	5	6	7	6	7	8

对于每个资产，相关的脆弱性和相应的威胁被考虑。如果存在没有相应威胁的脆弱性，或者存在没有相应脆弱性的威胁，则目前不存在风险（但是在这种情况下发生变化时应当小心）。现在，矩阵中的适当行标识资产价值，而适当列标识威胁发生的可能性和脆弱性易被利用性。例如，如果资产赋值 3，威胁是“高”的，脆弱性“低”，风险的度量是 5。假设资产赋值 2，例如用于修改，威胁级别“低”并且易被利用性“高”，那么风险的度量是 4。根据威胁可能性类别的数量、易用性类别和资产评估类别的数量，矩阵的大小可根据组织的需要进行调整。额外的列和行需要额外的风险措施。这种方法的价值在于对要处理的风险进行排序。

表 E.2 所示的类似矩阵是对映射被评估业务的影响的事件场景发生的可能性进行考虑的结果。一个事

事件场景的可能性是由一个威胁利用脆弱性的可能性给出的。该表将这种可能性映射到与事件场景相关的业务影响。由此产生的风险以 0 至 8 的尺度衡量，可以根据风险接受准则进行评估。这种风险等级也可以被映射到一个简单的总体风险评级，例如：

- 低风险：0 至 2；
- 中等风险：3 至 5；
- 高风险：6 至 8。

表 E.2

事件场景可能性		非常低 (非常不可能)	低 (不太可能)	中等 (可能)	高 (很可能)	非常高 (频繁)
业务影响	非常低	0	1	2	3	4
	低	1	2	3	4	5
	中等	2	3	4	5	6
	高	3	4	5	6	7
	非常高	4	5	6	7	8

E.2.3 示例 2 风险度量的威胁排序

可以使用请如表 E.3 中所示的矩阵或表来关联后果因素（资产价值）和威胁发生的可能性（考虑脆弱性方面）。第一步是在预定义的尺度（例如 1 至 5）上评估每个受威胁资产（表中的“b”列）的后果（资产价值）。第二步是评估每个威胁（表中的“c”列）的预定义尺度（例如 1 至 5）上出现威胁的可能性。第三步是乘法（b×c）计算风险度量。最后，威胁可以按照它们相关的风险度量来排序。注：在这个例子中，1 被认为是最低的结果和最低的发生的可能性。

表 E.3

威胁描述符 (a)	后果（资产）价值 (b)	威胁发生的可能性 (c)	风险度量 (d)	威胁排序 (e)
威胁 A	5	2	10	2
威胁 B	2	4	8	3
威胁 C	3	5	15	1
威胁 D	1	3	3	5
威胁 E	4	1	4	4
威胁 F	2	4	8	3

如上所述，这是一个程序，它允许按照优先顺序比较和排序具有不同后果和发生可能性的不同威胁，如这里所示。在某些情况下，有必要将货币价值与这里使用的经验尺度相联系。

E.2.4 示例 3 评估风险的可能性和可能后果的价值

在这个例子中，重点在于信息安全事件（即事件场景）的后果和确定应该优先考虑哪些系统。这是通过评估每个资产和风险的两个值来完成的，这两个值组合起来将决定每个资产的得分。当系统的所有资产分值相加时，确定该系统的风险度量。

首先，给每个资产分配一个值。这一价值与资产受到威胁时可能出现的潜在不良后果有关。对应于适用于资产的每个威胁，给资产赋值。

然后，评估可能性值。这是根据威胁发生的可能性和脆弱性易于被利用性的组合来评估的，参见表达

事件场景可能性赌表 E.4。

表 E.4

威胁的可能性	低			中			高		
脆弱性水平	低	中	高	低	中	高	低	中	高
事件场景的可能性值	1	1	2	1	2	3	2	3	4

接着，通过查找表 E.5 中的资产价值和可能性值的交集来分配资产/威胁分数。资产/威胁分数总计以产生资产总分。这个数字可以用来区分构成系统的一部分的资产。

表 E.5

资产价值	0	1	2	3	4
可能性值					
0	0	1	2	3	4
1	1	2	3	4	5
2	2	3	4	5	6
3	3	4	5	6	7
4	4	5	6	7	8

最后一步是将系统资产的所有资产总分合计，生成系统得分。这可以用来区分系统和确定哪个系统的保护应该被优先考虑。

在下面的例子中，所有的值都是随机选择的。

假设系统 S 具有三个资产 A1、A2 和 A3。也假设有两个威胁 T1 和 T2 适用于系统 S。让 A1 的值为 3。同样，让 A2 的资产价值为 2，A3 的资产价值为 4。

如果对于 A1 和 T1，威胁可能性低，并且利用脆弱性的容易程度中等，那么可能性值为 1（见表 E.4）。

资产/威胁分数 A1/T1 可以从表 E.5 导出，作为资产价值 3 和可能性值 1 的交叉点，即 4。类似地，对于 A1/T2，假设威胁可能性中等，并且脆弱性容易被利用性高，给出 A1/T2 评分为 6。

现在可以计算总资产分数 A1T，即 10。对于每个资产和适用的威胁计算资产总额。系统总得分是通过添加 A1T+A2T+A3T 来计算的。

现在可以比较不同的系统来建立优先级，在一个系统内不同的资产也同样如此。

上面的例子用信息系统表示。然而，类似的方法可以应用于业务流程。

附录 F

（资料性）

风险修正的约束条件

在考虑风险降低的约束条件时，应考虑以下约束：

——时间限制：

可以存在许多类型的时间约束。例如，控制应在组织管理者可接受的时间段内实施。另一种类型的时

时间约束是控制是否可以在信息或系统的生命周期内实现。第三种类型的时间约束可以是组织的管理者决定暴露于特定风险的可接受的时间段。

——财务约束：

控制不应该比实施它们所保护的风险价值更昂贵。应尽一切努力不超过分配的预算，并通过使用控制实现财务优势。然而，在某些情况下，由于预算限制，可能无法实现期望的安全性和风险接受水平。因此，这成为一个组织的管理者决定解决这种局面的决策。

如果预算减少了要实施的控制的数量或质量，则应格外小心，因为这可能导致隐含地保留比计划的更大的风险。制定的控制预算应当仅作为一个相当谨慎的限制因素。

——技术约束：

如果在选择控制时考虑技术问题，例如程序或硬件的兼容性，则很容易避免这些问题。此外，对现有过程或系统实施追溯性控制常常受到技术约束的阻碍。这些困难可能变动安全在程序和物理方面的平衡。为了实现安全目标，有必要修改信息安全方案。这可能发生在在降低风险而不降低生产率情况下控制不满足预期结果的情况下。

——运行约束

运行约束，例如需要运行 24/7 但仍然实施备份，可能导致复杂且昂贵的控制实现，除非它们从一开始就内置到设计中。

——文化约束：

在选择控制措施时，文化上的约束可能是特定于国家、部门、组织甚至组织内的某个部门的。并非所有的控制都适用于所有国家。例如，可以在欧洲的部分地区实施打包搜索，但不在中东的部分地区实施。

文化因素不容忽视，因为许多控制依赖于员工的积极支持。如果员工不理解对控件的需求，或者觉得在文化上不可接受，那么随着时间的推移，控件将变得无效。

——伦理约束：

基于社会规范的伦理变革，伦理约束可能对控制具有重大影响。这可能阻止在一些国家实施诸如电子邮件扫描之类的控制。依赖于地区或政府的伦理规范也可能改变信息隐私权。在一些行业中，例如政府和医疗保健，可能比其他行业更为关注这些。

——环境限制：

环境因素可以影响控制的选择，例如空间可用性、极端气候条件、周围的自然和城市地理。例如，在一些国家可能需要防震，而在其他国家则不需要。

——易用性：

一个糟糕的人机界面导致人为错误，并使控制无效。应选择在达到可接受的业务剩余风险水平的情况下最便于使用的控制。难以使用的控件会影响它们的有效性，因为用户可以尽可能地绕过或忽略它们。组织内的复杂访问控制可以鼓励用户查找替代的、未经授权的访问方法。

——人员约束：

应考虑实施控制的专门技能的可用性和薪金成本，以及在不利运行条件下在不同地点之间调动工作人员的能力。专业知识可能不容易用于实施计划控制或专业知识对于组织来说可能过于昂贵。其他方面，例如一些工作人员存在歧视没有经过安全审查的其他工作人员的倾向，可能对安全方针和实践产生重大影响。同样，需要招聘合适的人来工作，并找到合适的人，在安全检查完成之前可能产生招聘。在招聘前完成安全检查的要求是正常的，最安全的做法。

——集成新的和现有的控件的约束：

在现有基础设施中集成新的控制和控制之间的相互依赖性常常被忽略。如果存在与现有控件不一致或不兼容的情况，则可能不容易实现新的控制。例如，使用生物特征令牌进行物理访问控制的计划可能导致

与基于 PIN-pad 的现有系统进行访问控制的冲突。将控制从现有控制改变为计划控制的成本应包括增加到风险处理总成本的要素。由于与现有控制的干扰，可能不可能实现选定的控制。

参考文献

- (1) ISO/IEC 指南 73:《风险管理词汇》
- (2) ISO/IEC 16085,《系统与软件工程-生命周期过程-风险管理》
- (3) ISO/IEC 27001,《信息技术-安全技术-信息安全管理体系-要求》
- (4) ISO/IEC 27002,《信息技术-安全技术-信息安全控制实践守则》
- (5) ISO 31000,《风险管理-原则和准则》
- (6) NIST 特别出版物 800—12,《计算机安全概论: NIST 手册》
- (7) NIST 特别出版物 800—30,《信息技术系统风险管理指南-国家标准与技术研究所的建议》